

Buildweek_III_Isolare_Un_Host

Consegna

Obiettivi

In questo laboratorio, esaminerai i log raccolti durante lo sfruttamento di una vulnerabilità documentata per determinare gli host e il file compromessi.

- Parte 1 Esaminare gli Alert in Sguil
- Parte 2 Passare a Wireshark Pivoting)
- Parte 3 Passare a Kibana Pivoting)

Contesto / Scenario

La 5-tupla viene utilizzata dagli amministratori IT per identificare i requisiti per la creazione di un ambiente di rete operativo e sicuro. I componenti della 5-tupla includono un indirizzo IP e un numero di porta di origine, un indirizzo IP e un numero di porta di destinazione, e il protocollo in uso nel payload dei dati. Questo è il campo protocollo dell'header del pacchetto IP.

In questo laboratorio, esaminerai anche i log per identificare gli host compromessi e il contenuto del file compromesso.

Risorse Richieste

- Macchina virtuale Security Onion

Istruzioni

Dopo l'attacco, gli utenti non hanno più accesso al file chiamato confidential.txt. Ora esaminerai i log per determinare come il file è stato compromesso. Nota: Se questa fosse una rete di produzione, si raccomanda che gli utenti analyst e root cambino le loro password e si conformino all'attuale politica di sicurezza.

Svolgimento

Che tipo di transazioni si sono verificate tra il client e il server in questo attacco?

Dalla trascrizione che si nota chiaramente uno scambio di comandi shell tra un attore (SRC) e il bersaglio (DST).

L'attore esegue comandi tipici di un **accesso shell remoto**. La trascrizione sembra iniziare nel momento esatto in cui l'attaccante ha ottenuto accesso alla shell e tenta di enumerare il sistema tramite comandi come `whoami`, `ifconfig`, `hostname` ecc...

Il tutto termina con una sezione nella quale avviene la lettura di `/etc/passwd`, aggiunta di una riga con un nuovo utente `myroot` e verifica del contenuto aggiornato. Questo indica che l'attaccante ha ottenuto una shell remota sul sistema e l'ha usata per creare un account con privilegi (UID 0) — cioè una backdoor persistente con privilegi di root.

```
SRC: id
SRC:
DST: uid=0(root) gid=0(root)
DST:
SRC: nohup >/dev/null 2>&1
SRC:
SRC: echo uKgoT8McFDrCw7u2
SRC:
DST: uKgoT8McFDrCw7u2
DST:
SRC: whoami
SRC:
DST: root
DST:
SRC: hostname
SRC:
DST: metasploitable
DST:
SRC: ifconfig
SRC:
DST: eth0      Link encap:Ethernet  HWaddr 08:00:27:ab:84:07
DST:          inet addr:209.165.200.235  Bcast:209.165.200.255  Mask:255.255.255.224
DST:          inet6 addr: fe80::a00:27ff:feab:8407/64 Scope:Link
DST:
SRC:
DST:
SRC: echo "myroot::14747:0:99999:7:::" >> /etc/shadow
SRC:
SRC: grep root /etc/shadow
SRC:
DST: root:$1$avpfBJ1$x0z8w5UF9lv./DR9E9Lid.:14747:0:99999:7:::
DST: myroot::14747:0:99999:7:::
DST:
SRC: cat /etc/passwd
SRC:
DST: root:x:0:0:root:/root:/bin/bash
DST: daemon:x:1:1:daemon:/usr/sbin:/bin/sh

SRC: cat /etc/passwd | grep root
SRC:
DST: root:x:0:0:root:/root:/bin/bash
DST:
SRC: echo "myroot:x:0:0:root:/root:/bin/bash" >> /etc/passwd
SRC:
SRC: grep root /etc/passwd
SRC:
DST: root:x:0:0:root:/root:/bin/bash
DST: myroot:x:0:0:root:/root:/bin/bash
DST:
SRC: exit
SRC:
```

Cosa hai osservato? Cosa indicano i colori del testo rosso e blu?

In questo caso, all'interno di Wireshark, il colore rosso rappresenta le richieste inviate dall'attaccante mentre in blu le risposte della macchina.

L'attaccante esegue il comando `whoami` sul bersaglio. Cosa hai osservato? Cosa indicano i colori del testo rosso e blu?

La risposta del server conferma all'attaccante che ha avuto accesso allo user `root`.

```
id
uid=0(root) gid=0(root)
nohup >/dev/null 2>&1
echo uKgoT8McFDrCw7u2
uKgoT8McFDrCw7u2
whoami
root
hostname
metasploitable
ifconfig
eth0      Link encap:Ethern
          inet addr:209.165
```

Quali sono gli indirizzi IP e i numeri di porta di origine e destinazione per il traffico FTP?

L'indirizzo IP e la porta sorgente sono `192.168.0.11:52776` mentre l'IP e la porta di destinazione sono `209.165.200.235:21`.

Time	source_ip	source_port	destination_ip	destination_port
▶ June 11th 2020, 03:53:09.086	192.168.0.11	52776	209.165.200.235	21
▶ June 11th 2020, 03:53:09.086	192.168.0.11	52776	209.165.200.235	21

Quali sono le credenziali utente per accedere al sito FTP?

Le credenziali utilizzate per accedere al sito FTP sono le seguenti:

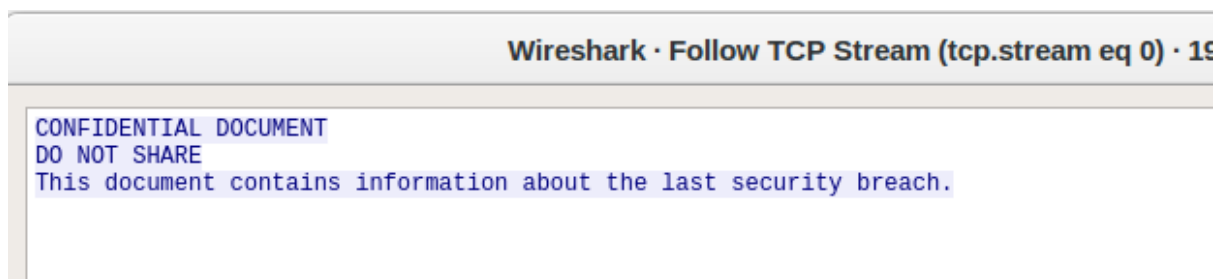
user → analyst

password → cyberops

```
OS Fingerprint -> 209.165.200.235:21 (link: etn
DST: 220 (vsFTPd 2.3.4)
DST:
SRC: USER analyst
SRC:
DST: 331 Please specify the password.
DST:
SRC: PASS cyberops
SRC:
DST: 230 Login successful.
DST:
```

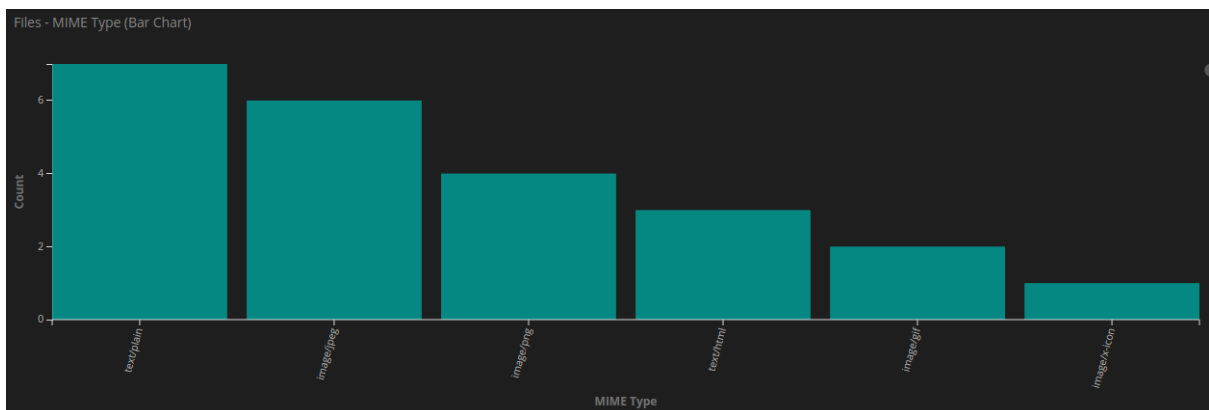
Ora che hai verificato che l'attaccante ha usato FTP per copiare il contenuto del file confidential.txt e poi cancellarlo dal bersaglio. Qual è il contenuto del file? Ricorda che uno dei servizi elencati nel grafico a torta è ftp_data.

Il contenuto del file è il seguente:



Quali sono i diversi tipi di file? Guarda la sezione MIME Type dello schermo. Scorri fino all'intestazione Files - Source. Quali sono le sorgenti dei file elencate?

I tipi di file che possiamo riscontrare all'interno dei log di Kibana sono i seguenti: **txt**, **jpeg**, **png**, **html**, **gif** ed **x-icon/.ico**.



Le source dai quali questi file provengono possiamo notare essere per la quasi totalità derivanti da traffico HTTP mentre uno solo dei file deriva da traffico FTP.

Source ↕	Count ↕
HTTP	22
FTP_DATA	1

Qual è il tipo MIME, l'indirizzo IP di origine e di destinazione associato al trasferimento dei dati FTP? Quando si è verificato questo trasferimento?

Il MIME type è **text/plain**, l'indirizzo IP sorgente è il **192.168.0.11** mentre quello di destinazione è il **209.165.200.235**

Files - Source IP Address		Files - Destination IP Address	
File IP Address ↕	Count ↕	IP Address ↕	Count ↕
192.168.0.11	1	209.165.200.235	1

Nei log dei file, espandi la voce associata ai dati FTP. Fai clic sul link associato all'alert _id. Qual è il contenuto testuale del file trasferito tramite FTP?

Il contenuto del file testo è **CONFIDENTIAL DOCUMENT DO NOT SHARE This Document contains information about the last security breach.**

[192.168.0.11:49817_209.165.200.235:20-6-1353594166.pcap](#)

```
Log entry:
{"ts":"2020-06-11T03:53:09.088773Z","fuid":"FX1iV63eSMAEiN16S2","tx_hosts":["192.168.0.11"],"rx_hosts":["209.165.200.235"],"conn_uids":["C2Jv8t
e":"FTP_DATA","depth":0,"analyzers":["SHA1","MD5"],"mime_type":"text/plain","duration":0.0,"is_orig":false,"seen_bytes":102,"missing_bytes":0,"overf
se","md5":"e7bc9c20bfd5666365379c91294d536b","sha1":"f7f54acee0342f61f8e63a10824ee11b330725"}
```

```
Sensor Name: seconion-import
Timestamp: 2020-06-11 03:53:09
Connection ID: CLI
Src IP: 192.168.0.11
Dst IP: 209.165.200.235
Src Port: 49817
Dst Port: 20
OS Fingerprint: 209.165.200.235:20 - Linux 2.6 (newer, 1) (up: 1 hrs)
OS Fingerprint: -> 192.168.0.11:49817 (distance 0, link: ethernet/modem)
SRC: CONFIDENTIAL DOCUMENT
SRC: DO NOT SHARE
SRC: This document contains information about the last security breach.
SRC:
```

```
DEBUG: Using archived data: /nsm/server_data/securityonion/archive/2020-06-11/seconion-import/192.168.0.11:49817_209.165.200.235:20-6.raw
QUERY: SELECT sid FROM sensor WHERE hostname='seconion-import' AND agent_type='pcap' LIMIT 1
CAPME: Processed transcript in 0.31 seconds: 0.06 0.16 0.00 0.10 0.00
```

[192.168.0.11:49817_209.165.200.235:20-6-1353594166.pcap](#)

Con tutte le informazioni raccolte finora, qual è la tua raccomandazione per fermare ulteriori accessi non autorizzati?

L'attacco ha mostrato che l'aggressore è riuscito a ottenere una shell remota sul sistema e successivamente a trasferire file tramite FTP. Questo implica due punti critici: la vulnerabilità sfruttata per l'accesso iniziale e l'utilizzo di credenziali valide per FTP.

Le azioni consigliate sono:

1. **Isolare immediatamente l'host compromesso**
Disconnettere la macchina 192.168.0.11 dalla rete per evitare ulteriore esfiltrazione o movimento laterale.
2. **Revocare e cambiare tutte le credenziali esposte**
Le credenziali FTP analyst/cyberops devono essere invalidate e sostituite.
Allo stesso modo, occorre modificare le password di tutti gli utenti privilegiati.
3. **Rimuovere la backdoor creata dall'attaccante**
Nel file /etc/passwd è stato aggiunto l'utente myroot con UID 0. Questo account deve essere eliminato e il file controllato per eventuali altre modifiche.
4. **Disabilitare o limitare l'uso di FTP in chiaro**
Il protocollo FTP trasmette credenziali e dati senza cifratura. È

necessario **sostituirlo con un protocollo sicuro come SFTP o FTPS.**

5. **Analizzare e correggere la vulnerabilità sfruttata**

Il traffico mostra uno shell access remoto, probabilmente sfruttando un servizio esposto. Occorre **patchare o disabilitare il servizio vulnerabile che ha consentito l'accesso.**

6. **Implementare monitoraggio continuo**

Attivare **alert su comandi sospetti** (es. creazione utenti, accesso a **/etc/passwd**) e su traffico verso indirizzi esterni come **209.165.200.235.**

In sintesi: isolare l'host, rimuovere la backdoor, sostituire le credenziali, disabilitare FTP e applicare patch. Solo dopo una bonifica completa e verifica dei log sarà sicuro reintrodurre la macchina nella rete.